

Privacy by Design in AI-Assisted Cybersecurity Policy Generation: Benchmarking Private RAG Against Frontier AI Models

Davide Carboni and Marcello Verona

The Lisbon Council, Brussels, Belgium

Abstract. Lorem ipsum dolor sit amet, consectetur adipiscing elit. Sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Ut enim ad minim veniam, quis nostrud exercitation ullamco laboris nisi ut aliquip ex ea commodo consequat. Duis aute irure dolor in reprehenderit in voluptate velit esse cillum dolore eu fugiat nulla pariatur. Excepteur sint occaecat cupidatat non proident, sunt in culpa qui officia deserunt mollit anim id est laborum.

Keywords: cybersecurity policy generation · large language models · retrieval-augmented generation · GDPR compliance · privacy-preserving AI · LLM evaluation

1 Introduction

Frontier AI models are now routinely used to draft cybersecurity policies, risk assessments, and compliance documentation. The value proposition is clear: scalable access to expertise that would otherwise require expensive consultants. The problem is equally clear: the data fed into these systems is by definition sensitive — organisational structure, threat models, known vulnerabilities, gap analyses, compliance regimes. Under GDPR Art. 28, 32, and 44–49 [2], NIS2 [3], and the AI Act [4], organisations in regulated sectors (healthcare, defence, finance) cannot route this data through processors without an adequate Data Processing Agreement (DPA), let alone across extra-EU boundaries without a transfer mechanism. Consumer-tier chat assistants based on frontier AI models are structurally incompatible with these requirements.

The industry has responded with two patterns: cloud RAG on proprietary providers (OpenAI Assistants, Azure OpenAI) — which improves grounding but does not address EU data residency, open-weight portability, or DPA; and private RAG on EU-resident open-weight models — which addresses all three. Recent work has begun to validate the effectiveness of AI-assisted policy generation: GPT-generated GRC policies have been shown to outperform human-written ones in certain contexts, particularly with tailored prompts [6,5]. Yet three conditions that regulated organisations cannot waive remain unaddressed: the privacy implications of routing sensitive organisational data to frontier processors without adequate DPA or EU residency guarantees; the reproducibility

of outputs across model versions; and the audit trail of cited sources. No study evaluates output quality and privacy posture simultaneously under the same rubric.

Research question: *Does a well-architected private RAG system (EU-region + DPA + open-weight) produce cybersecurity policies of comparable or superior quality to frontier AI models, while remaining GDPR-compliant by construction?*

We address this question by contributing: (i) an empirical benchmark comparing six AI configurations on 60 policy generation tasks in two regulated contexts; (ii) a controlled pairwise ablation for backbone selection within the same RAG architecture; and (iii) a joint quality-and-privacy evaluation framework applicable to regulated deployment contexts.

2 Related Work

LLM-based cybersecurity policy generation is an emerging area. McIntosh et al. [6] demonstrated that GPT-4 can generate GRC policies that outperform human-written ones in certain ransomware mitigation contexts; the study relies on human moderation and legal expert oversight throughout — an implicit acknowledgement that data handling risks are unresolved. Jawhar et al. [5] similarly demonstrate AI effectiveness for security policy and procedure drafting without addressing GDPR or data residency constraints. In both cases, quality is assessed informally without a replicable evaluation rubric, and no privacy-compliant architecture is tested.

LLM-as-judge methodology provides the evaluation backbone for our study [1]. The seven-criterion rubric we employ follows the structured grader design combining code-based checks with LLM-based scoring on Likert scales.

To our knowledge, no prior work evaluates both the output quality of AI-generated cybersecurity policies and the privacy compliance of the underlying architecture within a unified experimental framework.

[TODO: to be completed — add further related work on LLM-as-judge calibration (Zheng et al. NeurIPS 2023; G-Eval; AlpacaFarm) and on privacy-preserving inference architectures.]

3 Methodology

3.1 Experimental Design

The study adopts a two-phase design. In the first phase, a backbone selection experiment compares two open-weight models running on an identical private RAG architecture, in order to select the stronger candidate before the full benchmark. In the second phase, the selected private RAG configuration is benchmarked against four frontier AI configurations spanning the design space from unaugmented chat to cloud-hosted RAG.

All policy artefacts are generated from synthetic organisational profiles designed to represent typical regulated-sector environments (see Section 4). The

use of synthetic data allows full control over the experimental conditions and avoids any real data privacy concern in the evaluation pipeline itself.

3.2 Policy Generation

Each artefact is produced through a multi-turn adaptive interview. The system conducts 6–8 dialogue turns gathering organisational context (sector, size, regulatory regime, existing controls, cloud footprint), then generates the full policy document in a single final turn. The private RAG configurations augment this generation with retrieval from a curated knowledge base of 837 chunks drawn from NIST CSF 2.0, ISO/IEC 27001:2022, GDPR, NIS2, the AI Act, and sector-specific guidance for healthcare and defence. Frontier configurations either use no augmentation or rely on live web search.

3.3 Evaluation Framework

Each artefact is evaluated by an LLM-as-judge pipeline using Claude Opus 4.7 as the scoring model, following the structured grader blueprint described in [1]. The judge receives three inputs: the generated policy, the synthetic organisational profile used during generation, and a detailed scoring rubric. It returns a score from 1 to 5 on each of seven quality dimensions (see Section 4.3), accompanied by a brief scoring rationale.

The rubric combines objective checks — for example, presence of specific regulatory citations or mandatory policy clauses — with holistic LLM-scored assessments of coherence and contextual fit. This two-layer structure reduces sensitivity to surface variation while preserving sensitivity to substantive quality differences. Human calibration of the rubric against subject-matter expert judgement (Cohen’s κ) is underway on a sample of 6 artefacts and will be reported in the final version.

Rubric design rationale. The seven dimensions were derived in two steps. First, we mapped the grading dimensions proposed by Anthropic for research agents [1] — groundedness of claims against sources, coverage of key facts, source quality, and coherence of synthesis — onto the policy generation task, yielding *Evidence citation*, *Content quality*, *Source attribution*, and *Contextual adaptation* respectively. Second, we extended the rubric with three dimensions specific to the cybersecurity compliance domain: *Regulatory alignment* (coverage of applicable regulatory obligations, absent in generic agent evals); *Implementability* (actionability under real operational constraints); and *Resource consideration* (fitness for SME and public-sector organisations where budget and staffing are primary constraints). The extended rubric is publicly available with the evaluation code.

Table 1. Experimental configurations. GDPR compliance denotes the ability to operate under GDPR Art. 28 (DPA), Art. 32 (security measures), and Art. 44–49 (third-country transfers) as assessed from available provider documentation. † OpenAI Assistants API provides a DPA for API customers but does not guarantee EU data residency; data may be processed under SCCs outside the EU.

Model	Knowledge		GDPR
	Base	Web Provider	
gpt-4.1	–	– OpenAI consumer	×
gpt-4.1 + web search	–	✓ OpenAI + Bing	×
gpt-5.5 + web search	–	✓ OpenAI + Bing	×
gpt-4.1 (OpenAI Assistants RAG)	✓	– OpenAI Assistants partial†	
Kimi K2.5 (private RAG)	✓	– Nebius EU + DPA	✓
DeepSeek V3.2 (private RAG)	✓	– Nebius EU + DPA	✓

4 Experimental Setup

4.1 Configurations

We compared six configurations spanning the design space from consumer-tier AI chat to privacy-compliant private RAG (Table 1).

The first four configurations offer no EU data residency guarantee. The private RAG configurations (Kimi K2.5 and DeepSeek V3.2) are privacy-by-design: all inference runs within a Nebius EU region under a DPA, using open-weight models whose weights can be independently audited.

4.2 Backbone Selection

Before the full benchmark, we compared Kimi K2.5 and DeepSeek V3.2 under strictly identical conditions — same curated KB, identical system prompt, same EU-region provider (Nebius), and no model-specific prompt tuning. This controlled ablation isolates the backbone model as the sole variable, ruling out architecture or prompt design as confounds.

4.3 Evaluation Contexts and Policy Types

Each configuration was tested across two regulated contexts: **ctx-H** (a small Italian public hospital, ≈ 200 staff, subject to Italian healthcare regulations, NIS2, and GDPR) and **ctx-M** (a NATO detachment in Romania, subject to NATO information security policy). Five policy types were generated per context: Password Policy, Data Protection Policy, Access Control Policy, Incident Response Policy, and General Cybersecurity Policy, yielding 60 artefacts in total.

Each artefact was evaluated on seven quality dimensions (Section 3.3) with 1–5 Likert anchors:

1. **Content quality:** accuracy and completeness of cybersecurity controls

2. **Contextual adaptation:** fit to the specific organisational context
3. **Evidence citation:** grounding in standards and regulatory sources
4. **Implementability:** actionability and practical feasibility
5. **Regulatory alignment:** coverage of applicable compliance requirements
6. **Source attribution:** traceable references to cited sources
7. **Resource consideration:** acknowledgement of organisational resource constraints

5 Results

5.1 Backbone Selection: Kimi K2.5 vs. DeepSeek V3.2

The pairwise judge returned 10/10 comparisons in favour of Kimi K2.5 over DeepSeek V3.2. Both models ran on the same private RAG architecture with identical system prompt and KB; the result is attributable solely to the models' differential ability to follow structured citation directives. The gap is concentrated on normative traceability: source attribution (4.10 vs. 2.30, $\Delta = 1.80$) and regulatory alignment (4.20 vs. 2.90, $\Delta = 1.30$). Implementability is the sole dimension where the models converge ($\Delta = 0.60$, 3 ties). Kimi K2.5 was selected as the private RAG backbone for the full benchmark.

5.2 Quality Scores Across Configurations

Table 2 reports mean scores across all ten artefacts per configuration (two contexts $\times$ five policy types). gpt-5.5 + web search achieves the highest average (4.60), followed by Kimi K2.5 private RAG (4.15) and gpt-4.1 + web search (3.90). The OpenAI Assistants RAG configuration falls below the no-RAG gpt-4.1 baseline on the overall average.

6 Discussion

6.1 Backbone Selection Within the Same RAG Architecture

The 10/0 pairwise result and the per-dimension gap analysis establish that, under equal conditions, Kimi K2.5 substantially outperforms DeepSeek V3.2 on dimensions requiring normative traceability. The concentration of the gap on source attribution ($\Delta = 1.80$) and regulatory alignment ($\Delta = 1.30$) suggests that the two models differ in their ability to follow structured citation directives — a finding that is independent of prompt design, since both models received identical instructions. Implementability ($\Delta = 0.60$, 3 ties) is the sole dimension where the models converge, suggesting that general instruction-following is comparable but domain-specific citation discipline is not.

[TODO: to be completed — discuss implications for backbone selection methodology; generalise finding beyond this specific pair.]

Table 2. Mean quality scores by configuration (1–5 Likert scale). Bold: highest value per row. DeepSeek V3.2 was eliminated after backbone selection (Section 5.1) and is not included here. Cost estimates based on average token counts from generation logs and API list prices (May 2026). Latency: median wall-clock time, client-side.

Dimension	gpt-4.1		gpt-5.5	gpt-4.1	Kimi
	gpt-4.1	+web	+web	(Asst.)	K2.5
Content quality	4.10	4.00	5.00	4.00	4.60
Contextual adaptation	4.60	4.40	5.00	4.50	5.00
Evidence citation	3.60	4.00	5.00	3.80	4.10
Implementability	4.20	4.50	4.60	4.10	4.20
Regulatory alignment	3.90	3.90	4.90	4.10	4.20
Source attribution	4.20	4.50	4.50	3.80	4.10
Resource consideration	2.00	2.00	3.20	1.60	2.50
Average	3.83	3.90	4.60	3.70	4.15
Cost / query (USD)	~0.02	~0.03	TBD	~0.07	~0.05
Latency (s)	33	30	278	41	36
Tokens leaving EU	all	all	all	all	0

6.2 Frontier Benchmark Interpretation

The 9% quality gap between the best frontier configuration (gpt-5.5 + web search, avg. 4.60) and the private RAG configuration (Kimi K2.5, avg. 4.15) is concentrated in ctx-H, where the Italian regulatory web corpus is rich and live web search provides substantive grounding. The gap halves in ctx-M (NATO classified), precisely the context where privacy posture matters most and where web search offers the least domain-specific value.

The apparent advantage of gpt-5.5 + web search must be discounted by three caveats: two processors without DPA (OpenAI and Bing), 10× higher cost, 7× higher latency, and citations drawn from blogs and vendor whitepapers rather than institutional sources. The audit trail of a private RAG with a curated KB is deterministic and reproducible; the audit trail of a frontier model with live web search is neither.

[TODO: to be completed — add per-context breakdown (ctx-H vs ctx-M); discuss OpenAI Assistants RAG underperformance; address self-preference bias in LLM-as-judge.]

7 Conclusion

For regulated organisations the question is not “which model writes the best policy” but “which architecture produces adequate policies under the constraint that no data shall leave the perimeter.” A private RAG on EU-resident open-weight models is today a technically competitive option: it achieves 90% of frontier quality at one-tenth the cost, with full GDPR compliance and a deterministic

audit trail. The marginal quality gain offered by frontier AI models does not justify the privacy cost they impose.

A further open question concerns the relative weight of two distinct privacy properties: *legal domicile* of the provider versus *physical residency* of the data. A provider legally incorporated in the EU but operating sub-processors outside the EU may, in practice, offer weaker GDPR protection than an EU-domiciled provider with a clean sub-processor chain, even if the latter is less well-known. Conversely, a non-EU provider (e.g., subject to the US CLOUD Act) that operates servers exclusively in an EU region may offer strong data residency guarantees while remaining legally exposed to extra-EU compelled disclosure. Our experimental setup treats GDPR compliance as a binary dimension assessed from published provider documentation; a more nuanced analysis should evaluate the full sub-processor chain and the legal jurisdiction of each entity in the inference path. We leave this as a direction for future work.

[TODO: to be completed — add limitations, future work (human calibration Cohen’s κ , broader context coverage, additional open-weight models), and reproducibility statement (code + data release).]

Acknowledgements

This work has been carried out in the context of the COcyber project (*Coordination Between the Cybersecurity Civilian and Defence Spheres*), funded by the European Union under the Horizon Europe programme, Grant Agreement No. 101158606 (Call DIGITAL-ECCC-2023-DEPLOY-CYBER-04). Views and opinions expressed are those of the authors only and do not necessarily reflect those of the European Union or the European Cybersecurity Competence Centre (ECCC). Neither the European Union nor the ECCC can be held responsible for them.

References

1. Anthropic: Demystifying evals for AI agents. Anthropic Engineering Blog (2024), <https://www.anthropic.com/engineering/demystifying-evals-for-ai-agents>, accessed: May 2026
2. European Parliament and Council of the European Union: Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data (GDPR). Regulation, Official Journal of the European Union (2016)
3. European Parliament and Council of the European Union: Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the union (NIS2). Directive, Official Journal of the European Union (2022)
4. European Parliament and Council of the European Union: Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (AI act). Regulation, Official Journal of the European Union (2024)
5. Jawhar, S., Miller, J.R., Bitar, Z.: AI-based cybersecurity policies and procedures. In: Proc. 3rd IEEE Int. Conf. on AI in Cybersecurity (ICAIC). Houston, TX, USA (2024). <https://doi.org/10.1109/ICAIC60265.2024.10433845>

6. McIntosh, T.R., Liu, T., Susnjak, T., Alavizadeh, H., Ng, A., Nowrozy, R., Watters, P.: Harnessing GPT-4 for generation of cybersecurity GRC policies: A focus on ransomware attack mitigation. *Computers & Security* **134**, 103424 (2023). <https://doi.org/10.1016/j.cose.2023.103424>